



SECURING WHAT **MATTERS** ALWAYS

COMPANY PROFILE

2026

WHO WE ARE

Built by practitioners. Delivered with precision.

Hexdrift is a cybersecurity consulting and implementation firm founded to close a persistent gap in the market - the disconnect between audit findings and real-world remediation. We exist for organisations that need more than a report. They need a partner who can translate risk into action, and action into results.

Operating across India, the GCC region, and Europe, Hexdrift brings together technical depth and regulatory fluency that most boutique firms cannot offer. Our practitioners carry direct experience across enterprise security engagements, compliance projects, and security programme builds - and that experience is what every client engagement draws from.

We work with organisations where security is not optional: regulated industries, data-sensitive businesses, and enterprises operating under frameworks such as ISO 27001, India's DPDP Act, and Saudi Arabia's PDPL. In these environments, the quality of advice and the quality of execution both matter - and we do not separate the two.



MISSION

To make enterprise-grade cybersecurity accessible, actionable, and effective - for organisations that cannot afford to get security wrong.



VISION

To be the most trusted cybersecurity partner for growth-stage and mid-market organisations across India and the GCC - known not for the problems we find, but for the ones we solve.

OUR APPROACH

Security that goes beyond the checklist

Most security engagements end at the finding. A penetration test produces a report. An audit identifies gaps. A compliance review flags deficiencies. What happens next is left to the client to figure out - often without the expertise or bandwidth to act effectively.

Hexdrift is structured differently. We treat discovery and remediation as a continuous loop, not two separate contracts. Our engagements are designed to leave organisations genuinely more secure - with the controls, processes, and awareness to sustain that posture over time.

Risk Led Prioritisation

We anchor every engagement to business risk - not just technical severity. This ensures effort is directed where it matters

Regulation Aware Execution

Our work is shaped by the compliance landscape - DPDP, PDPL, ISO 27001, NCA, SAMA - ensuring findings and

Practitioner Delivery

No account managers passing work downstream. Senior practitioners lead and deliver every engagement..

Geographic Fluency

Direct operational experience in India and the GCC means we understand the regulatory, cultural, and commercial

Transparent Communication

We write and speak plainly. Technical findings are translated into language that boards, legal teams, and operations can act

Long-Term Partnership Mindset

We build relationships, not transactions. Most of our work evolves from initial engagements into ongoing security

VULNERABILITY MANAGEMENT

Continuous visibility into your attack surface - prioritised by risk, not noise.

Overview

Vulnerability Management is the ongoing process of identifying, classifying, prioritising, and remediating security vulnerabilities across an organisation's infrastructure, endpoints, applications, and cloud environments. Unlike a point-in-time assessment, Hexdrift's Vulnerability Management service delivers continuous visibility - ensuring that new vulnerabilities are captured as they emerge and that remediation efforts are directed where they matter most. We combine automated scanning with practitioner-led analysis to cut through the noise. Not every critical CVSS score is a critical business risk - and not every low-severity finding is benign. Our risk prioritisation methodology contextualises findings against your specific environment, asset criticality, and threat landscape.

Why It Matters

The average time between vulnerability disclosure and exploitation continues to compress. Organisations without a structured vulnerability management programme are reactive by default - responding to breaches rather than preventing them. A well-executed programme significantly reduces your exploitable attack surface and provides the evidence base needed for board-level security reporting.

Deliverables

- ✓ Vulnerability assessment reports (per scan cycle)
- ✓ Risk-prioritised remediation roadmap
- ✓ Asset inventory and classification register
- ✓ Executive summary and trend dashboards
- ✓ Remediation verification reports
- ✓ Monthly/quarterly programme review

Methodology



Asset Discovery

Comprehensive enumeration of all in-scope assets - on-premises, cloud, hybrid. No asset left unscanned.



Continuous Scanning

Automated scanning on a defined cadence, supplemented with authenticated scans for depth of



Risk Prioritisation

Findings contextualised by asset criticality, exploitability, and business impact - not just CVSS score.



Remediation

Structured remediation plans with ownership, deadlines, and verified closure. Progress reported to

Engagement Model

Delivered as an annual managed service with defined scan frequency (weekly, monthly, or continuous). Includes practitioner review at each cycle, remediation support, and quarterly programme health reviews. Minimum engagement: 6 months.

Relevant Frameworks

ISO 27001 | NIST CSF | NCA ECC | DPDP | PDPL

PENETRATION TESTING

Think like an attacker. Defend like a practitioner.

Overview

Penetration Testing is a structured, authorised simulation of real-world attack techniques against an organisation's systems, networks, and applications. The goal is to identify exploitable vulnerabilities before a malicious actor does - and to provide a clear, evidence-based picture of what an attacker could achieve if they did. Hexdrift conducts penetration tests across multiple domains: network infrastructure (internal and external), web applications, APIs, mobile applications, and cloud environments. Each engagement is scoped carefully with the client, aligned to a defined threat model, and executed by experienced practitioners - not junior testers following scripted playbooks. We offer black-box (no prior knowledge), grey-box (partial knowledge), and white-box (full knowledge) testing methodologies, selected based on the client's objective - adversarial realism, efficiency, or code-level depth.

Why It Matters

Vulnerability scanners find known issues. Penetration testers find what attackers actually exploit - including chained vulnerabilities, logic flaws, and misconfigurations that no automated tool surfaces. A penetration test provides the evidence needed to justify security investment, satisfy auditor requirements, and close the gap between assumed security and actual security.

Deliverables

- ✓ Executive summary (board/management-ready)
- ✓ Technical findings report with evidence
- ✓ Severity-rated vulnerability register
- ✓ Remediation guidance per finding
- ✓ Retest / remediation verification
- ✓ Live debrief session

Methodology



Scoping & Threat Modeling

Define targets, methodology, rules of engagement, and threat actor profile relevant to the client's business.



Reconnaissance

Passive and active information gathering - OSINT, network mapping, service enumeration - to build an attacker's view.



Exploitation

Controlled exploitation of identified vulnerabilities to demonstrate real-world impact, with careful attention to scope boundaries.



Reporting & Debrief

Detailed findings report with severity, evidence, and remediation guidance. Live debrief session with technical and executive audiences.

Engagement Model

Project-based engagement. Duration varies by scope - web application tests typically 5-10 days; infrastructure tests 5-15 days; full red team exercises 3-6 weeks. Retesting included within the engagement window. Annual pentest programmes available at reduced rates.

Relevant Frameworks

OWASP Top 10 | NIST SP 800-115 | ISO 27001 A.12.6 | NCA ECC

APPLICATION SECURITY & SECURE CODE REVIEW

Security embedded in the build - not bolted on at the end.

Overview

Application Security (AppSec) covers the practices, tools, and expertise required to build and maintain software that is resistant to attack. Hexdrift's AppSec service spans the full software development lifecycle - from threat modelling in early design phases, through secure code review during development, to SAST/DAST-assisted testing prior to release. Secure Code Review is a practitioner-led examination of source code to identify security vulnerabilities introduced during development - issues that penetration testing alone may not surface, including insecure cryptographic implementations, injection flaws, broken access control, and sensitive data exposure. We work with development teams on their terms - integrating into existing SDLC processes, CI/CD pipelines, and sprint cycles - rather than imposing external frameworks that slow delivery.

Why It Matters

The earlier a vulnerability is identified in the development lifecycle, the cheaper it is to fix. A vulnerability found in production can cost 30x more to remediate than one caught in code review. As regulatory scrutiny of software security increases - particularly under DPDP and PDPL - organisations can no longer treat application security as optional. Customer data, business logic, and critical infrastructure all run on software that needs to be built securely from the ground up.

Deliverables

- ✓ Threat model documentation
- ✓ Secure code review report with line-level references
- ✓ SAST/DAST findings with severity and remediation
- ✓ Security requirements checklist
- ✓ Developer remediation guidance session
- ✓ Post-fix verification review

Methodology



Threat Modeling

Map application architecture, data flows, trust boundaries, and identify security risks before a line of code is reviewed.



Static Analysis (SAST)

Automated tooling combined with practitioner review to identify code-level vulnerabilities across the codebase.



Dynamic Analysis (DAST)

Runtime testing of the application in a running state - simulating attacker interaction with live endpoints.



Review & Remediation

Findings documented with code-level remediation guidance. Developer sessions to ensure fixes address root cause, not just symptom.

Engagement Model

Offered as project-based code review engagements or as an ongoing AppSec advisory retainer embedded in the SDLC. Project engagements are scoped by codebase size and language stack. Retainer model available for teams shipping regularly.

Relevant Frameworks

OWASP Top 10, ASVS | SANS CWE Top 25 | ISO 27034 | NIST SSDF

04 / 05

DPDP / PDPL COMPLIANCE CONSULTING

Navigate data protection law with precision - not guesswork.

Overview

India's Digital Personal Data Protection Act (DPDP) and Saudi Arabia's Personal Data Protection Law (PDPL) represent a significant shift in how organisations must handle personal data in two of the GCC and South Asia's largest markets. Compliance is not optional - and the window for readiness is closing. Hexdrift's DPDP/PDPL Compliance Consulting service takes organisations from uncertainty to readiness. We conduct structured gap assessments against the applicable law, map data flows across the organisation, identify high-risk processing activities, develop the policy and notice framework required, and produce a time-bound remediation roadmap that legal, IT, and operations can execute together. We translate legislative language into practical obligations - and practical obligations into implementable controls. Our practitioners hold working knowledge of both regulatory regimes, including the interplay between DPDP/PDPL requirements and existing frameworks such as ISO 27001 and NIST.

Why It Matters

Non-compliance with DPDP and PDPL carries significant penalties, reputational risk, and - critically - the risk of regulatory investigation triggered by a data breach. Organisations operating across India and the GCC face dual-jurisdiction obligations that most standard compliance templates do not address. Early readiness is a competitive advantage in sectors where enterprise clients and government counterparties are beginning to require evidence of compliance as a procurement condition.

Deliverables

- ✓ Regulatory applicability and gap assessment report
- ✓ Data flow and processing activity register
- ✓ Data Protection Impact Assessment (DPIA)
- ✓ Privacy policy and internal data handling policies
- ✓ Consent management framework
- ✓ Compliance remediation roadmap

Methodology



Regulatory Mapping

Map applicable obligations under DPDP / PDPL to the organisation's operating model, data categories, and processing activities.



Gap Assessment

Structured assessment across people, process, and technology to identify compliance gaps and risk-rank them.



Data Mapping & DPIA

Document personal data flows, processing purposes, lawful bases, and conduct Data Protection Impact Assessments for high-risk activities.



Policy & Roadmap

Develop privacy notices, internal policies, consent mechanisms, and a prioritised compliance roadmap with

Engagement Model

Project-based engagement delivered in defined phases. Initial gap assessment typically 3-4 weeks. Full compliance programme build 8-16 weeks depending on organisation complexity. Ongoing advisory retainer available post-implementation.

Relevant Frameworks

India DPDP Act | Saudi PDPL | GDPR | ISO 27701 | NIST Privacy Framework

05 / 05

GRC ADVISORY

Governance, risk, and compliance - structured for your organisation, not a

Overview

Governance, Risk, and Compliance (GRC) Advisory covers the strategic and operational framework through which organisations manage security risk, satisfy regulatory requirements, and demonstrate accountability to customers, partners, and boards. Hexdrift's GRC Advisory service is not about checkbox compliance. It is about building security governance that actually functions - risk registers that are used, controls that are tested, policies that are followed, and boards that receive accurate information. We help organisations design and implement GRC frameworks aligned to ISO 27001, NIST CSF, NCA Essential Cybersecurity Controls, and sector-specific requirements. For organisations pursuing ISO 27001 certification, we provide readiness advisory, internal audit preparation, and gap closure support - without acting as the certification body, preserving objectivity and compliance.

Why It Matters

Immature GRC functions expose organisations to regulatory penalty, contractual liability, and reputational damage - often without any technical breach occurring. Boards and senior leadership are increasingly held accountable for security governance failures. A structured GRC framework transforms security from a reactive cost centre into a governed, measurable function that supports business objectives rather than hindering them.

Deliverables

- ✓ GRC framework design and implementation plan
- ✓ Information security risk register
- ✓ Policy and procedure library
- ✓ Control mapping to chosen framework(s)
- ✓ Internal audit readiness review
- ✓ Board and management reporting templates

Methodology



Framework Selection

Select and tailor the appropriate GRC framework(s) based on regulatory context, sector, and organisational maturity.



Risk Assessment

Conduct structured risk assessment across information assets, processes, and third parties. Produce a risk register with ownership.



Control Design

Map controls to framework requirements, identify gaps, and design remediation. Develop policy library, procedures, and governance



Implementation & Review

Support implementation across teams, conduct internal audit readiness reviews, and provide ongoing advisory to maintain programme effectiveness.

Engagement Model

Delivered as a structured project with defined phases, or as an ongoing GRC advisory retainer for organisations needing continuous programme support. ISO 27001 readiness engagements are scoped separately based on current maturity level and target certification timeline.

Relevant Frameworks

ISO 27001:2022 | NIST CSF 2.0 | NCA ECC | SAMA CSF | CIS Controls v8



Ready to work together?

Whether you are exploring a first engagement or looking for a long-term security partner, we are ready to listen and respond with clarity.



+91 751 095 6551



info@hexdrift.com



www.hexdrift.com



 **hexdrift**